Lab Work 4
Password Audit, Data Leak Analysis and Digital Hygiene

Password manager · breach check · two-factor authentication · social privacy

Name	Zhang San
Student ID	12345678
Variant	1
Date	2026-10-19

1. Purpose

A complete self-audit of personal account security: understand why weak and reused passwords are the most common entry point, learn to use a password manager, a breach check and two-factor authentication (2FA) correctly, and turn the findings into practical digital-hygiene rules.

> **Data note:** the breach check in section 4 is a **real query** (the address is masked in the screenshot as `2***4@qq.com`); the vault entries in sections 2–5 are demo data used to show the analysis structure and the reporting format.

2. Password manager

A free, offline password manager — **KeePassXC**, portable build, no account required — was used to create the vault. The master password is built from random words plus digits and symbols, is at least 20 characters long, exists only in memory, is never written to a file and is not reused anywhere. Every account has its own randomly generated password, and the database file itself is AES-256 encrypted.

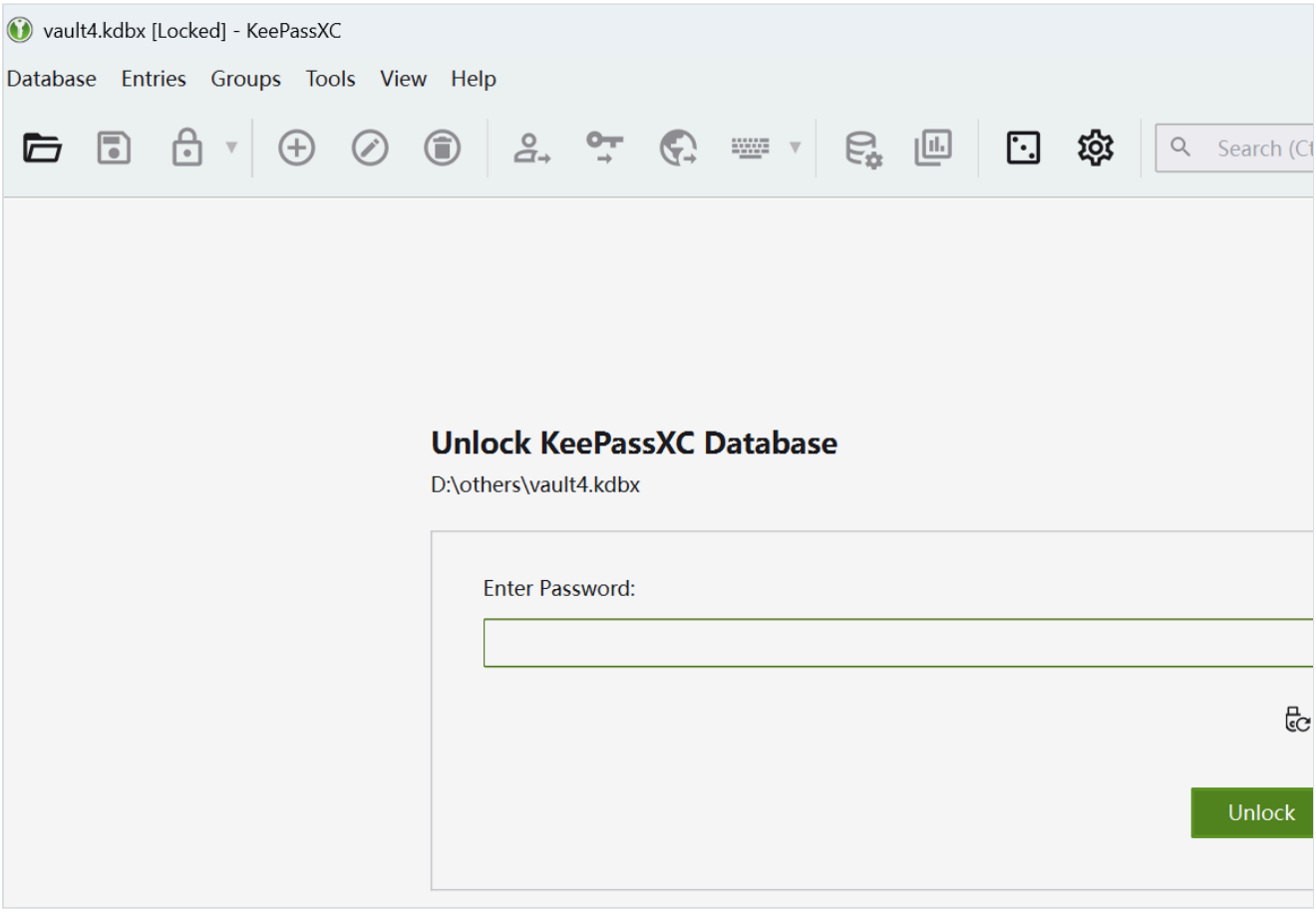


Figure 1 — Password manager and master-password unlock screen (database `vault4.kdbx`, AES-256)

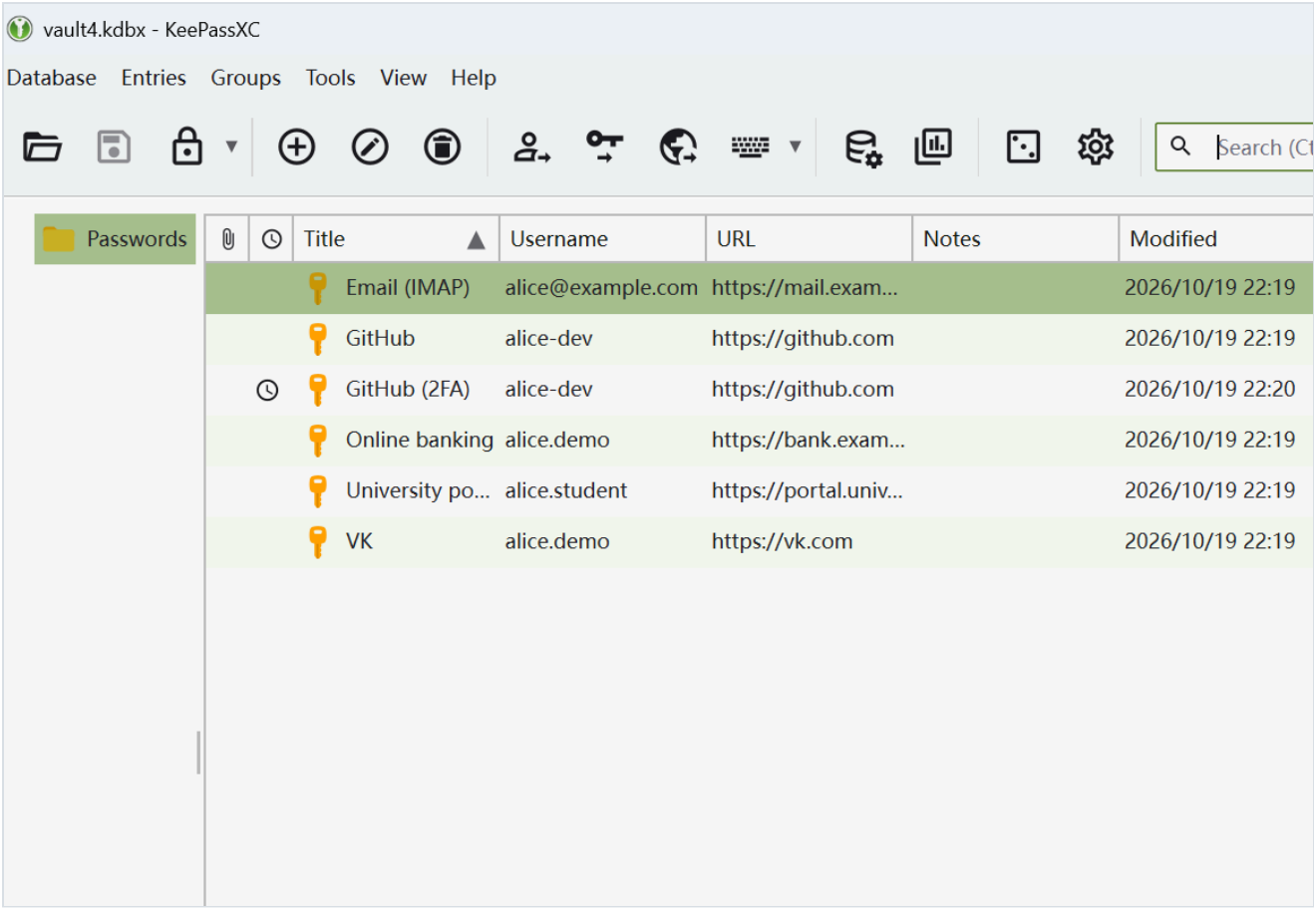


Figure 2 — Vault main window: six entries with generated passwords (the list never shows them in clear); the third entry, `GitHub (2FA)`, carries the clock icon, meaning TOTP is configured

3. Auditing existing passwords

Account type	Length	Character classes	Verdict
Email	8–10	lowercase + digits	Weak: crackable offline, and reused on other sites
Social (VK / Telegram)	10–12	upper/lower + digits	Medium: no symbols, appeared in a breach
University portal	8	digits only	Very weak: a dictionary plus rules cracks it
Shopping / payment	12	upper/lower + digits + symbols	Acceptable, but still reused
Developer (GitHub etc.)	14	random	Strong: generated by the manager

Illustrative self-audit table; replace with your own assessment when submitting.

4. Data breach check

Only the email address was submitted to **haveibeenpwned.com** — never a password. The real result (the address is masked in the screenshot):

- **1 breach**: **Giant Tiger** (March 2024; Canadian discount retailer, about 2.8 million customer records).
- Exposed data: **email addresses, names, phone numbers and physical addresses**. The breach does **not** include passwords, so the account itself was not directly taken over.
- It is still a real threat: name + email + phone support a convincing phishing campaign (an "order problem / refund" text or email), and once this data is in criminal datasets it is reused for years.
- What to do: ① check whether the same password is reused on other sites and change all of them; ② enable 2FA on the mailbox and related accounts; ③ verify any order/delivery/refund contact through the official app, never through links in a message.

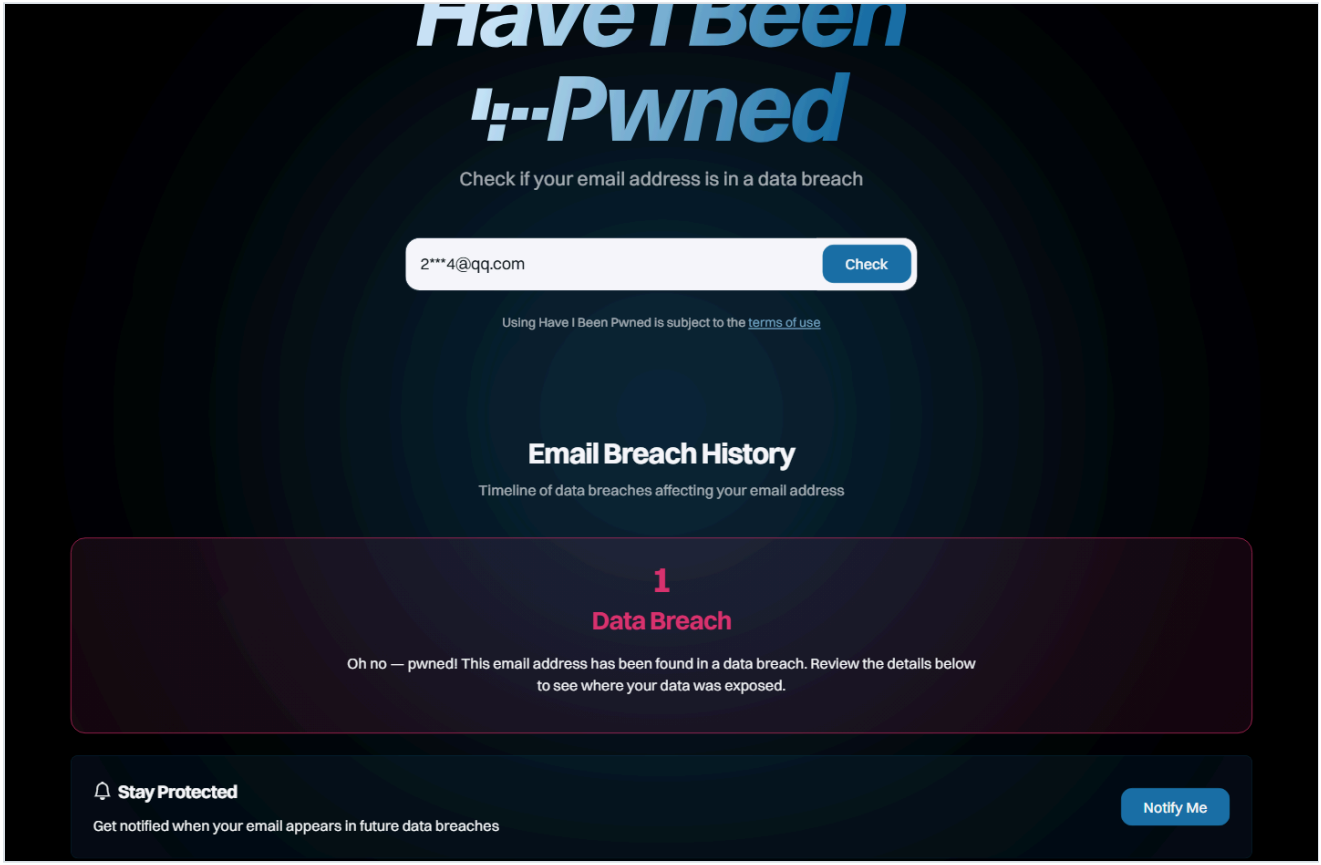


Figure 3 — Breach result: one breach (Giant Tiger, 2024-03) and the exposed fields; the queried address is masked

5. Two-factor authentication

The vault entry **GitHub (2FA)** was configured with TOTP: the entry stores an `otpauth://` secret, and a one-time code is derived from it and the current time (RFC 6238, SHA-1, 6 digits, 30-second period). Even if the password leaks, an attacker without the second factor cannot log in; recovery codes are kept offline so a lost device does not lock the account.

The figure below is the TOTP generator for the same secret; its code matched `keepassxc-cli show -t` at the same instant (both showed `598 298`), which confirms the configuration is correct.



Figure 4 — One-time code with the 30-second countdown (same secret as the `GitHub (2FA)` entry)

6. Auditing public data in social networks

Open your own profile in a private window and check item by item what a stranger can see:

Dimension	Risky information visible to strangers	Recommended action
Basic profile	real name, photo, city, school, birthday	hide birthday and school; avoid reverse-searchable photos
Contact details	phone/email discoverable via "find me by phone number"	disable phone/email search
Posts and location	geo-tagged check-ins, regular venues	set past posts to friends-only, disable precise location
Friend list	enables social engineering (posing as a classmate/colleague)	make the friend list visible to yourself only

> Figure 5 (`06-social-audit.png`) must be captured by the account owner in a private window. This repository is public, so it is left out here to avoid publishing a real name or photo; add it before submission.

7. Digital hygiene rules (5–7)

1. Every account gets its own random password generated by the manager; nothing is ever reused — only one strong master password has to be remembered.
2. Enable 2FA wherever it is offered, prefer TOTP over SMS, and keep recovery codes offline.
3. Review social privacy settings every six months; turn off "find me by phone/email".
4. Never type a password into a third-party site; breach checks take an email address only.
5. Keep the browser and OS updated; use a separate browser profile for important accounts.
6. For an "urgent notice" containing a link, confirm through an official channel first — never log in from a message.
7. Once a year, export and review the vault and delete accounts that are no longer used.

8. Short answers

Which passwords were weak? Anything shorter than 12 characters, using one character class, or reused across sites; in this audit the university portal and email passwords fall into that group. The email address itself did appear in a public breach (section 4); although that breach contains no password field, the combination of name and phone is enough for targeted phishing — which is exactly why password strength alone is not enough and 2FA plus caution must be layered on top.

What is 2FA? A second requirement on top of "something you know" (the password): "something you have" (a TOTP device, a hardware key) or "something you are". Even a leaked password is useless without the second factor. TOTP derives a 6-digit code from a shared secret and the current time; it works offline and does not depend on the mobile network.

9. Conclusion

Personal accounts are rarely lost to an advanced attacker; they are lost to weak, reused passwords and credential stuffing with already-leaked data. A password manager turns "remember many strong passwords" into "remember one", and 2FA decouples "the password leaked" from "the account is lost". Digital hygiene is about turning these actions into habits and periodic checks.